

SMARTFUZZ · AI-DRIVEN VULNERABILITY ASSESSMENT

Security Assessment Report.

Verified findings · CVSS-scored · Remediation included

TARGET	https://owasp.org/
SCANNED	2026-05-20 03:24 IST
REFERENCE	dab7fe9d-ce64-424b-ad13-d216c336e40b

OVERALL RISK POSTURE

HIGH

01 · EXECUTIVE SUMMARY

Assessment Overview

This document presents the findings of an automated security assessment performed against <https://owasp.org/> on 2026-05-20 03:24 IST. The SmartFuzz engine evaluated the target against a configurable set of vulnerability classes — SQLi, XSS, RCE, SSRF, Command Injection, Auth Bypass, IDOR, NoSQL, XXE, SSTI, and Open Redirect — using AI-synthesised payloads and differential response analysis. The overall risk posture is currently evaluated as **High**.

TOTAL FINDINGS

8

CRITICAL

0

HIGH

8

MEDIUM

0

LOW

0

PAYLOADS TESTED

118

MAX CVSS

6.1

AVG CVSS

6.1

FORMS CRAWLED 2

GET PARAM SETS 1

VULN CLASSES 1

02 · AUTHORISATION & CONSENT

Legal Pre-Scan Gate

Before this assessment was launched, the SmartFuzz operator was presented with a mandatory legal consent dialog. The scan only proceeded once the operator explicitly confirmed each of the following statements:

- ✓ I own this target, or I have written authorisation from the owner.
- ✓ I understand this scan will send potentially malicious payloads.
- ✓ I accept full legal responsibility for the consequences of this scan.

INFORMATION TECHNOLOGY ACT, 2000 · §43 · §66

Unauthorised access to a computer resource, including the unauthorised scanning of computer systems for vulnerabilities, constitutes a punishable offence under the Information Technology Act, 2000 (India) §43 and §66. Similar provisions exist in most jurisdictions worldwide — notably the Computer Fraud and Abuse Act (United States), the Computer Misuse Act 1990 (United Kingdom), and the Convention on Cybercrime (Council of Europe). SmartFuzz documents operator authorisation before each scan to ensure all testing is performed in compliance with applicable law.

03 · FINDINGS SUMMARY

8 Verified Finding(s)

#	CLASS	PARAMETER	SEVERITY	CVSS
1	Open Redirect	reponame	HIGH	6.1
2	Open Redirect	reponame	HIGH	6.1
3	Open Redirect	reponame	HIGH	6.1
4	Open Redirect	reponame	HIGH	6.1
5	Open Redirect	reponame	HIGH	6.1
6	Open Redirect	reponame	HIGH	6.1
7	Open Redirect	reponame	HIGH	6.1
8	Open Redirect	reponame	HIGH	6.1

04 · DETAILED FINDINGS

Per-Finding Analysis

FINDING 01 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=https%3A%2F%2Fevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.141 s

INJECTED PAYLOAD

<https://evil.com>

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 02 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=%2F%2Fevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.141 s

INJECTED PAYLOAD

//evil.com

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 03 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=%2F%2F%2Fevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.141 s

INJECTED PAYLOAD

///evil.com

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 04 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=%5C%5Cevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.141 s

INJECTED PAYLOAD

`\\evil.com`

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 05 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=http%3A%2F%2Fgoogle.com%252f%252eevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.125 s

INJECTED PAYLOAD

`http://google.com%2f%2eevil.com`

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 06 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=%2F%5Cevil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.093 s

INJECTED PAYLOAD

```
/\evil.com
```

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 07 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=http%3A%2F%2Flocalhost%40evil.com
METHOD	GET
STATUS CODE	301

RESPONSE TIME 0.093 s

INJECTED PAYLOAD

http://localhost@evil.com

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

FINDING 08 Open Redirect

HIGH

6.1

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

PARAMETER	reponame
URL	https://owasp.org/donate?reponame=http%3A%2F%2F127.0.0.1.evil.com
METHOD	GET
STATUS CODE	301
RESPONSE TIME	0.093 s

INJECTED PAYLOAD

http://127.0.0.1.evil.com

RESPONSE EVIDENCE

```
<html> <head><title>301 Moved Permanently</title></head> <body> <center><h1>301 Moved Permanently</h1></center> <hr><center>nginx</center> </body> </html>
```

05 · REMEDIATION GUIDANCE

Recommended Mitigations

Open Redirect

- 01 Validate redirect destinations against an allowlist of trusted domains.
- 02 Reject relative URLs starting with // or \ and non-http(s) schemes (javascript:, data:).
- 03 Prefer server-side indirection: redirect via short tokens that map to URLs server-side.
- 04 Show a confirmation interstitial before navigating off-site.
- 05 Reference: OWASP Top 10 A01:2021 — Broken Access Control

DISCLAIMER

This report was generated automatically by the SmartFuzz engine. Findings have been verified via differential response analysis, but false positives may still be present. Results should be reviewed and validated by a qualified security professional before remediation work is scheduled. SmartFuzz is provided as a research and educational tool; the operator is solely responsible for ensuring all scanning activity is performed against authorised targets and in compliance with applicable law.